System and Network Security

Dr. Ashok Kumar Das

Professor
Center for Security, Theory and Algorithmic Research
International Institute of Information Technology, Hyderabad

E-mail: *ashok.das@iiit.ac.in*
URL: `https://www.iiit.ac.in/faculty/ashok-kumar-das/`
`https://sites.google.com/view/iitkgpakdas/`

Internet Security Protocol (IPSec) (Part 2)

Encapsulating Security Payload (ESP) Protocol

Encapsulating Security Payload (ESP) Protocol

- The AH protocol does not provide privacy, only source authentication and data integrity.
- IPSec later defined an alternative protocol, called the **Encapsulating Security Payload (ESP)** protocol, that provides source authentication, integrity, and privacy.
- ESP adds a header and trailer.
- ESP's authentication data is added at the end of the packet, which makes its calculation easier.

Encapsulating Security Payload (ESP) Protocol

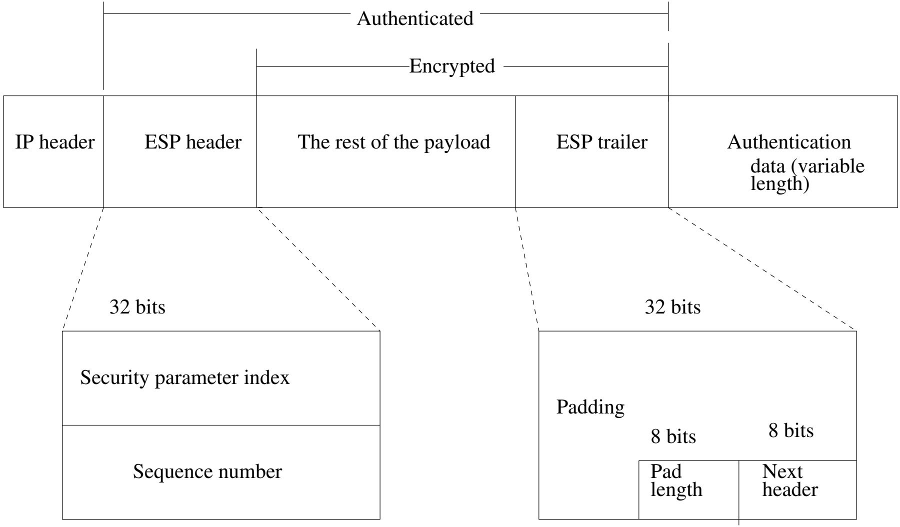

Figure: ESP protocol under transport mode

Encapsulating Security Payload (ESP) Protocol

The ESP procedure follows the following steps:

- **Step 1:** An ESP trailer is added to the payload.
- **Step 2:** The payload and the trailer are encrypted.
- **Step 3:** The ESP header is added.
- **Step 4:** The ESP header, payload, and ESP trailer are used to create the authentication data.
- **Step 5:** The authentication data is added to the end of the ESP trailer.

Fields for ESP Protocol

- **Next header:** The 8-bit next header field defines the type of payload carried by the IP datagram (such as TCP, UDP or ICMP). It is similar to that defined for the AH protocol.
- **Padding:** The variable length field (0 to 255 bytes) of 0s serves as padding.
- **Pad length:** This 8-bit field is the number of padding bits. The value is between 0 and 255. The maximum value of this is rare.
- **Sequence number:** A 32-bit sequence number provides ordering information for a sequence of datagrams. The sequence numbers prevent a playback/replay attack.
  - The sequence number is not repeated even if a packet is retransmitted.
  - A sequence number does not wrap around after it reaches 2^{32}; a new connection must be established.

Fields for ESP Protocol (Continued...)

- **Security parameter index:** The 32-bit security parameter index (SPI) field is similar to that defined for the AH protocol.
- **Authentication data:** The authentication data field is the result of applying an authentication scheme to parts of the datagram. Note that the difference between the authentication data in AH and ESP is that in AH, part of the IP header is included in the calculation of the authentication data; in ESP, it is not.

ESP Protocol

IPv4 and IPv6

- IPSec supports both IPv4 and IPv6.
- In IPv6, however, AH and ESP are part of the extension header.

AH and ESP Protocol

AH versus ESP

- ESP protocol was designed after the AH protocol was already in use.
- ESP does whatever AH does with additional functionality (privacy/confidentiality).
- **Question:** Why do we then need AH ?

Services provided by IPSec

- Two protocols: AH and ESP, can provide several security services for packets at the network layer.
- AH does not provide confidentiality (privacy).

Table: IPSec services

Services	AH	ESP
Access control	Yes	Yes
Message authentication (message integrity)	Yes	Yes
Entity authentication (data source authentication)	Yes	Yes
Confidentiality (privacy)	No	Yes
Replay attack protection	Yes	Yes

Services provided by IPSec

- **Access control:** IPSec provides access control indirectly using a Security Association Database (SAD). When a packet arrives at a destination and there is no Security Association (SA) already established for this packet, the packet is discarded.
- **Message integrity:** It is provided by both AH and ESP. A digest of data is created and sent by the sender to be checked by the receiver.
- **Entity authentication:** The security association (SA) and the keyed-hash digest of the data sent by the sender authenticate the sender of the data in both AH and ESP.
- **Confidentiality:** The encryption of the message in ESP provides confidentiality. AH, however, does not provide confidentiality. If confidentiality is needed for application, one needs to use ESP instead of AH.

Services provided by IPSec

Procedure for replay attack protection:

- In both protocols (AH and ESP), the replay attacks are prevented by using sequence numbers and a *sliding receiver window*.
  - Each IPSec header contains a unique sequence number when the Security Association (SA) is established.
  - The sequence number starts from 0 and increases until the value reaches $2^{32} - 1$ (the size of the sequence number field is 32 bits).
  - When the sequence number reaches the maximum, it is reset to 0 and, at the same time, the old security association is deleted and a new one is established.
  - To prevent processing duplicate packets, IPSec mandates the use of a fixed-size window at the receiver. The size of the window is determined by the receiver with a default value 64.

Services provided by IPSec

- **Procedure for replay attack protection**

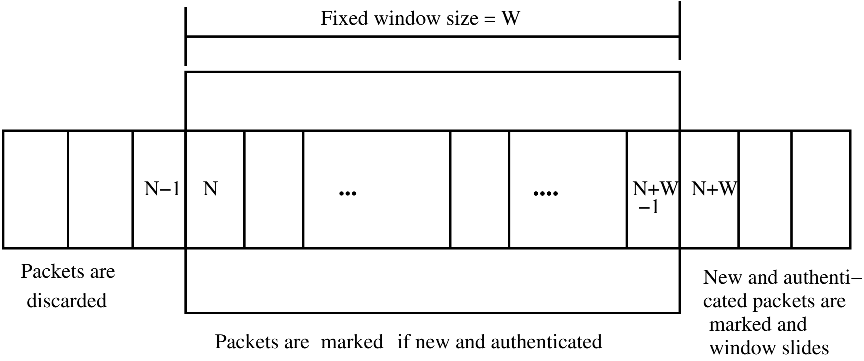

Figure: Replay window

Services provided by IPSec

Procedure for replay attack protection

- When a packet arrives at the receiver, one of three things can happen, depending on the value of the sequence number i, where $0 \leq i \leq 2^{32} - 1$.
  - Case 1: $i < N$.
    This puts the packet on the left of the window. The packet is discarded because it is either a duplicate packet or its arrival time has expired.
  - Case 2: $N \leq i \leq N + W - 1$.
    This puts the packet inside the window. In this case, if the packet is new (not marked) and it passes the authentication test, the sequence number i is marked and accepted. Otherwise it is discarded.
  - Case 3: $i > N + W - 1$.
    This puts the packet at the right of the window. If the packet is authenticated, the corresponding sequence number i is marked and the window slides to the right to cover the newly marked sequence number. Otherwise, the packet is discarded.

- **Drawbacks on procedure for replay attack protection**
  - It may happen that a packet arrives with a sequence number much larger then $N + W - 1$ (very far from the right edge of the window).
  - In this case, the sliding of the window may cause many unmarked numbers to fall to the left of the window. These packets, when they arrive, will never be accepted.
  - Example: If a packet arrives with sequence number $N + W + 3$, the window slides and the left edge will be at the beginning of $N + 3$. Now if a packet with sequence number $N + 2$ arrives, it will be discarded because it is out of the window.

Services provided by IPSec

- **Zhao-Wu's improved solution for replay attack protection**
  - This protocol uses anti-replay window.
  - **Lemma 1:** In the IPSec anti-replay window, the sequence number i will be dropped if and only if there exists at atleast one sequence number j, received earlier than i, where $j \geq i + w$, w is the window size.
  - **Lemma 2:** In the receiving anti-replay window with the window size w, sequence number i will be dropped due to the window shift if and only if at least w different sequence numbers that are larger than i have arrived earlier than i before.

F. Zhao and S. F. Wu, "Analysis and Improvement on IPSec Anti-Replay Window Protocol", in ICCN 2003: Proceedings of the 12th International Conference on Computer Communications and Networks, pages 553-558, 2003, IEEE Computer Society Press.

`https://ieeexplore.ieee.org/abstract/document/1284223`

References

- Behrouz A. Forouzan, “Cryptography & Network Security”, Special Indian Edition, 2008.
- F. Zhao and S. F. Wu, “Analysis and Improvement on IPSec Anti-Replay Window Protocol”, in ICCN 2003: Proceedings of the 12th International Conference on Computer Communications and Networks, pages 553-558, 2003, IEEE Computer Society Press.

Thank You !!!